

Managing Security Culture Half Life

Bob Lord · Former CSO, DNC

Steve Tran · Former CSO, DNC



Three Acts

1

The Audit

My first-90-days assessment — what I found, what was unexpected.

2

The Flashback

Bob answers the question — with the human and environmental factors beneath the technical decisions.

3

The Evolution

My retrospective: which programs survived the transition, which were evolved.

□ **Is your program institutionalized, or is it just you?**

ACT I · STEVE TRAN

The First 90 Days



Inholes
exhale. f
well. All o
this is part
of the story
you will tell.



Expectation vs. Reality

✓ CREDIT WHERE DUE

Hardware Security Keys

Widely deployed, providing strong MFA against phishing.

Laptops Locked Down

Robust endpoint security configurations were already in place.

⚠ THE UNEXPECTED

Email Scanning

No third-party email scanning in use, despite an enterprise-scale threat surface for highly targeted attacks.

Credential Management

Absence of a centralized credential management tool, leading to fragmented password practices.

Cloud Management

Cloud infrastructure needed structure and consistent governance policies.

Roles & Responsibilities

Team members often wore multiple, overlapping hats, leading to ambiguity in security responsibilities.

Russian government hackers penetrated DNC, stole opposition research on Trump

June 14, 2016 More than 10 years ago



By [Ellen Nakashima](#)

Russian government hackers penetrated the computer network of the Democratic National Committee and gained access to the entire database of opposition research on GOP presidential candidate Donald Trump, according to committee officials and security experts who responded to the breach.

The intruders so thoroughly compromised the DNC's system that they also were able to read all email and chat traffic, said DNC officials and the security experts.



PRESS RELEASE

U.S. Charges Russian GRU Officers with International Hacking and Related Influence and Disinformation Operations

Thursday, October 4, 2018

For Immediate Release

Office of Public Affairs

Conspirators Included a Russian Intelligence “Close Access” Hacking Team that Traveled Abroad to Compromise Computer Networks Used by Anti-Doping and Sporting Officials and Organizations Investigating Russia’s Use of Chemical Weapons

A grand jury in the Western District of Pennsylvania has indicted seven defendants, all officers in the Russian Main Intelligence Directorate (GRU), a military intelligence agency of the General Staff of the Armed Forces of the Russian Federation, for computer hacking, wire fraud, aggravated identity theft, and money laundering.

ACT II · BOB LORD

Human Problems Wearing a Technical Costume



Human-Factors Lessons

1. Deadlines Don't Move, So Risk Tolerance Does

Elections have a hard deadline. Security doesn't get a vote.

- No do-overs. You can't push the election because your posture isn't ready.
- Risk tolerance isn't static. What's non-negotiable in January becomes negotiable in October.
- A campaign's actual objective is to win, not to be secure. Security has to serve that objective or it gets deprioritized.



Human factors insight: In mission-critical, fixed-deadline environments, security must align with the primary objective, *as the risk calculus changes*.

2: "Security keys don't knock on doors"

Hardware Keys Are an Investment, Not a Tax

- 2019: deployed FIDO keys at DNC, prepping for state parties, campaigns
- Common pushback: no budget for hardware.
- The real cost comparison: a phishing breach vs. the price of a key.
- The "donuts and coffee" moment: Money existed for field canvassing, not for keys. The organizer's answer said it all: security keys don't knock on doors.



Human factors insight: Security competes with the mission's core activity for every dollar.

Human-Factors Lessons

3: Building Resilient Systems on an Unpredictable Budget

You can't build a security program on a budget you can't forecast.

- Parties and campaigns don't sell a product. They run on *donations*.
- That means the budget months out is a guess, and it can shrink as easily as it grows.
- The design question: how do you defend against common attacks without locking into tools you might have to cut later?



Human factors insight: Design for resilience against likely threats first, assuming some tools may not survive the next fundraising cycle. How can we change people and processes rather than layering on security tools?

4: The Cycle Creates Technical Debt That Nobody Chose

After the election, big turnover. The systems stay.

- Inherently cyclical. Turnover spikes after midterms/presidential cycles.
- Institutional knowledge walks out the door with the people. The next team often doesn't know what's running, why, or who still depends on it.
- Shutting things down safely takes real work: figuring out dependencies, confirming nothing breaks, coordinating with whoever might still need it. That work competes with everything else on a shrinking, overworked team.
- The path of least resistance is to leave it running. Nobody gets blamed for a system that quietly stays on. Someone might get blamed for the one they turned off that turned out to matter.



Human factors insight: Technical debt in this world isn't just accumulated — it's decommissioning debt, and it compounds every cycle because the incentive always favors leaving things alone.

When You Can't Buy Security, You Have to Redesign It

1

Don't secure it. Turn it off.

Continuous archaeological work: finding systems nobody remembered existed, tracking down whoever might still own or depend on them, then negotiating a graceful sunset for each one. End result: every system in the datacenter was decommissioned, saving over \$1M in recurring annual spend.

2

The cheaper path was the secure path.

The fleet ran on Windows with Active Directory. Modernizing that backend securely was going to cost significant time and money. Retiring the aging Windows fleet for Chromebooks cost less and was more secure. Security keys deployed in 2019 and 2020. (If it was possible on that budget then, it's possible for you now.)

3

The Chair didn't *endorse* security. He *enforced* it.

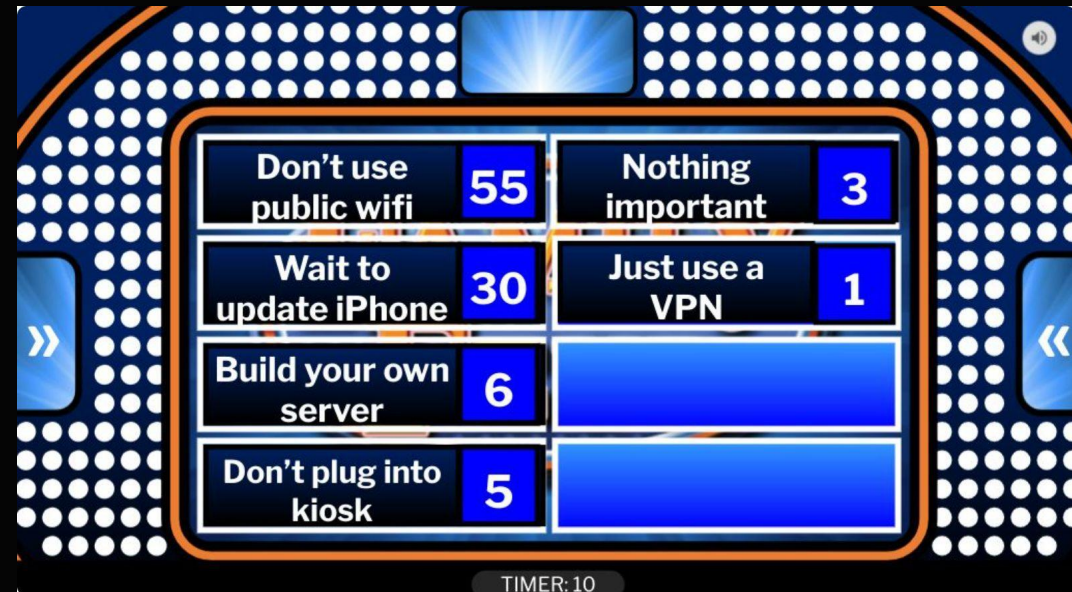
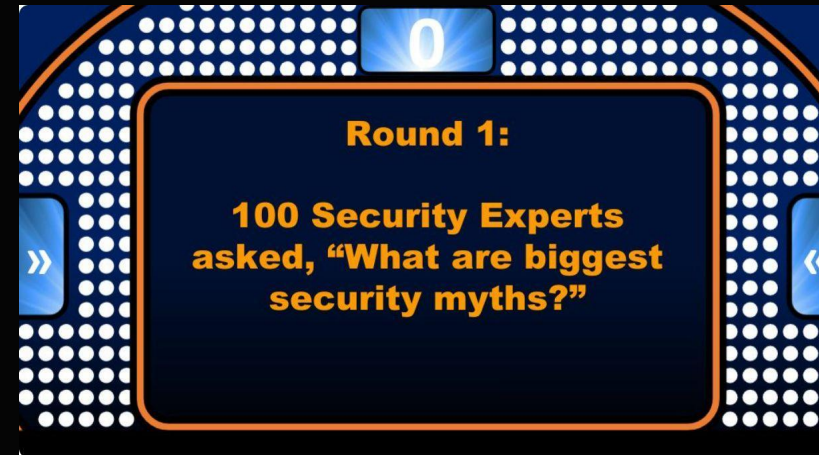
He raised hardware key enrollment at senior staff meetings and made it a priority for his team. After the deadline passed, he asked for a list of everyone who hadn't enrolled and called them personally to ask when they'd finish. This wasn't advocacy from the top. It was a senior executive directly driving the transformation.

4

Fight the hacklore, not the spy thriller.

A lot of energy inside the ecosystem went toward defending against exotic threats like public wifi paranoia, while common, boring attacks were what actually got people hacked. The DNC Security Checklist redirected focus to the basics that stop the most frequent attacks.

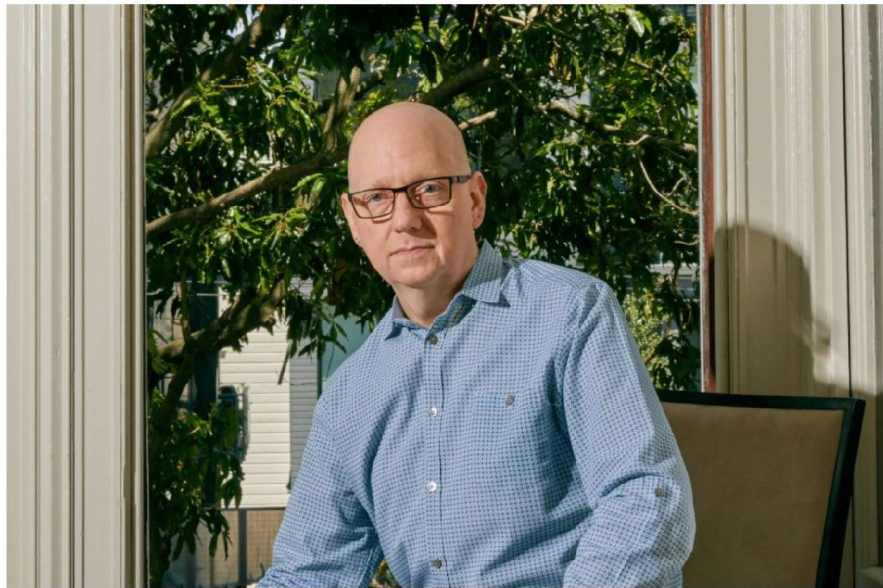
Over the top events create memorable lessons



The D.N.C. Didn't Get Hacked in 2020. Here's Why.

A devastating email breach of the D.N.C. roiled Democrats in the final months of 2016. An unassuming security official made it his mission to prevent a recurrence.

 Share full article  



Bob Lord took a six-figure pay cut in January 2017 and headed to Washington to become the D.N.C.'s first chief information security officer. Christie Hemm Klok for The New York Times

 By Nicole Perlroth

Published May 29, 2021 Updated Aug. 3, 2021

As the country learns more about a broad Russian hijacking of American federal agencies and private companies and now

For some reason, people remember toilet humor

A “Bobmoji”— a digital caricature of Mr. Lord — hangs above the men’s urinal and adorns the walls of the women’s restroom, reminding staff members of the checklist.



The Succession Test

I inherited a transformed organization. The question wasn't whether Bob's work was good — it was whether it was **institutionalized**. Succession is a natural experiment that most security programs never get to run. Here's what the data showed.

✓ Survived

The paranoid security culture. Hardware security key investment. Chromebook-first philosophy. Google Workspace ecosystem. The cultural shift away from Windows. The security-first mindset was deeply embedded — arguably too deeply in some dimensions.

↻ Evolved

The TikTok ban didn't survive — I applied my MGM Studios experience to make a more nuanced risk-based call. IT/DevOps team structure was reorganized: DevOps moved to Engineering, enabling those teams to become self-sufficient in security without constant oversight.

✗ Had to Be Built

Cloud security upgrade! Knowledge management portal. Formal documentation. KPIs. A security risk committee. A 20-page CSO transition playbook. Structured program mapping to strategic goals. The cultural foundation was solid; the institutional scaffolding was reinforced.

Three Questions to Take Home

Succession is the most honest test a security program can face. If it doesn't survive the founder, it was never truly institutionalized. Ask these questions before you find out the hard way.

1 **Is your program institutionalized, or is it just you?**

Can you distinguish between executive buy-in, sponsorship, and **ownership** — and can you honestly say your program has the latter? If your departure would cause atrophy, the answer is no.

2 **Have you made risk visible — or just managed it yourself?**

Risk that only you can see is risk that only you are accountable for. Making the accountability graph legible to others is itself a security control. In cyclical organizations, it may be the most important one.

3 **Are your decisions based on security architecture or cultural architecture?**

The highest-leverage interventions at the DNC weren't technical — they were *behavioral*. The executive who personally calls non-compliant staffers is doing more security work than the engineer who deploys the control.

❏ **If a security program can't survive its founder, it was never truly institutionalized.**

Preserving the culture (not the tech)

Before you can preserve security culture across leadership transitions, you need to know what's worth preserving. Most CISOs inherit programs without a cultural inventory — and lose what worked before they even knew it existed.

Audit Your Cultural Assets

Identify which behaviors, rituals, and norms are genuinely **reducing risk versus** creating compliance theater. Which routines actually change how people think about security? What would quietly atrophy if you left tomorrow — and would anyone even notice?

Design for CISO-Agnostic Continuity

Think about how to **encode your strongest cultural elements** into institutional structures — onboarding programs, runbooks, executive relationships, and team rituals — so they survive not just one leadership transition, but multiple. Culture that lives only in a person is culture at risk.

Thank you!

Bob: **bob@hacklore.org**

Steve: **steve@onciso.com**

